Koban — Data Retention and Disposal Policy

Owner: Vishhvak Srinivasan (sole operator and security contact) **Effective:** 2026-07-06 · **Review cadence:** every 6 months, jointly with the Information Security Policy **Scope:** all consumer financial data handled by the Koban personal-finance application: data retrieved from connected providers (Plaid, Teller, SnapTrade, SimpleFIN), operator-authored annotations, authentication data, and operational copies (backups, local development stores).

Koban is a single-operator application: the only data subject is the operator. Retention decisions therefore serve the operator's own ledger-history needs, and disposal is always available to the data subject on demand because the data subject *is* the operator.

1. Data inventory

Category	Contents	Store
Financial data	Account metadata, balances, transactions (read-only copies from connected institutions)	PostgreSQL (production: Railway; development: operator machine)
Annotations	Categories, tags, notes, review states authored by the operator	Same database, attached to transactions
Provider credentials	Access tokens for Plaid items, Teller enrollments, SnapTrade user, SimpleFIN access URL	Railway service variables / git-ignored `.env`; provider tokens additionally in the database `sync_state` table where the application persists them
Auth data	Better Auth account record, session records, second-factor material (passkey public keys, TOTP secret)	Same database
Derived data	Search embeddings and semantic documents generated from transactions	Same database

No card numbers or institution login credentials are ever stored: providers expose read-only tokens; institution credentials are entered only on the institution's or provider's own pages.

2. Retention

- **Financial data and annotations** are retained while the relevant provider connection is active, because the application's purpose is a continuous personal ledger. There is no automatic time-based purge; ledger history is the product.
- **Provider credentials** are retained while the connection is active and rotated or revoked on suspicion of exposure (see Information Security Policy §3, §8).
- **Sessions** expire per Better Auth defaults; expired sessions carry no long-term retention.
- **Backups/quarantined stores** (e.g., corrupted-store snapshots created by the application's recovery path) are reviewed at each policy review and deleted when no longer needed for recovery.

3. Disposal

Disposal paths, all available to the operator at any time:

1. **Full application data deletion:** the in-app local-data reset (Settings) deletes stored accounts, transactions, annotations, embeddings, and provider sync state from the database in one operation.
2. **Per-provider disposal:** disconnecting an item/enrollment at the provider (Plaid Portal at my.plaid.com, Teller, SnapTrade dashboard, SimpleFIN Bridge) terminates data flow; the operator then deletes the associated local records via reset or targeted deletion.
3. **Credential disposal:** tokens are revoked at the provider and removed from Railway variables / `.env`.
4. **Infrastructure disposal:** deleting the Railway project destroys the production database and its volume on the platform (Railway is SOC 2 Type II certified; platform-side media disposal is covered by its certification). Local development stores are deleted with the repository/data directory on a FileVault-encrypted disk, and disk disposal follows standard encrypted-media practice (destroy the key by erasing the disk).

4. Compliance posture

- The application holds data about exactly one natural person — the operator — so no third-party data-subject requests can arise. Should the application ever serve additional users, this policy must be revised before onboarding them.
- Data is never sold or shared with third parties; outbound data flows are limited to the connected providers and, only if explicitly enabled by the operator, an operator-configured AI enrichment endpoint (disabled by default).

- This policy is reviewed on the stated cadence and its review is logged in the Information Security Policy review log.